

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 (Grype/NVD CVSS-weighted) · Generated 2026-06-29 · Commit: 61ed8c3 · Model: 0.5·CVE_severity + 0.3·exposure + 0.2·business_criticality

Ranked Remediation Backlog

#	Coordinate	Ver	Band	Risk	Top CVE / Issue	CVE Count	Fix Versior
1	org.apache.logging.log4j:log4j-core	2.14.1	CRITICAL	9.0	CVE-2021-44228 (CVSS 10.0)	7	2.17.1
2	com.fasterxml.jackson.core:jackson-databind	2.9.8	CRITICAL	9.0	CVE-2020-8840 (CVSS 9.8)	55	2.13.4.2
3	org.apache.logging.log4j:log4j-api	2.14.1	CRITICAL	9.0	CVE-2021-44228 (CVSS 10.0)	2	2.17.1
4	mysql:mysql-connector-java	8.0.30	CRITICAL	8.2	CVE-2023-22102 (CVSS 8.3) + GPL-2.0	1	8.0.33
5	com.fastxml.jackson.core:jackson-databind	2.9.8	CRITICAL	8.0	TYPOSQUATTED — REMOVE	0	REMOVE
6	commons-io:commons-io	2.4	HIGH	6.5	CVE-2024-47554 (CVSS 7.5)	2	2.15.1
7	com.google.guava:guava	24.1.1-jre	HIGH	6.3	CVE-2023-2976 (CVSS 5.5)	2	32.0.0-jre
8	org.apache.commons:commons-lang3	3.4	MEDIUM	5.8	CVE-2025-48924 (CVSS 5.3)	1	3.14.0

Component Scores (Detail)

Dependency	CVE Severity Score	Exposure Score	Business Criticality	Weighted Risk
log4j-core 2.14.1	10.0 (CVSS 10 + density)	8.0	8.0	9.0 CRITICAL
jackson-databind 2.9.8 (fasterxml)	10.0 (CVSS 9.8 + density)	8.0	8.0	9.0 CRITICAL
log4j-api 2.14.1	10.0 (CVSS 10 + density)	8.0	8.0	9.0 CRITICAL
mysql-connector-java 8.0.30	8.3	8.0	8.0	8.2 CRITICAL
com.fastxml...:jackson-databind (TYPOSQUAT)	0.0	7.0	5.0	8.0 CRITICAL (floored)

commons-io 2.4	7.5 (+ density)	7.0	2.0	6.5 HIGH
guava 24.1.1-jre	6.0 (CVSS 5.5 + density)	7.0	2.0	6.3 HIGH
commons-lang3 3.4	5.3	7.0	2.0	5.8 MEDIUM

Scan Summary

Metric	Value
Total dependencies scanned	8
Total CVEs found	70
CRITICAL CVEs	16
HIGH CVEs	42
MEDIUM CVEs	11
LOW CVEs	1
Typosquatted dependencies	1
License violations	1
Untrusted repositories	1 (HTTP mirror)
Risk band CRITICAL	5
Risk band HIGH	2
Risk band MEDIUM	1

Supply-Chain Issues

- TYPOSQUATTED:** `com.fastxml.jackson.core:jackson-databind:2.9.8` — GroupId `com.fastxml` impersonates `com.fasterxml.jackson.core`. Coordinate does not exist on Maven Central. Remove immediately.
- LICENSE VIOLATION:** `mysql:mysql-connector-java:8.0.30` — GPL-2.0 license conflicts with permissive-only policy. Replace with `com.mysql:mysql-connector-j:8.0.33` (commercial license) or use MariaDB connector.
- UNTRUSTED REPOSITORY:** `http://insecure-mirror.example.net/maven2` — Plain HTTP Maven repository. Artifacts are susceptible to MITM substitution. Remove this repository entry.

Priority Recommendations

- P0 — IMMEDIATE:** Remove `com.fastxml.jackson.core:jackson-databind:2.9.8` (typosquatted supply-chain attack vector).
- P0 — IMMEDIATE:** Upgrade `log4j-core` and `log4j-api` 2.14.1 → 2.17.1 (Log4Shell CVE-2021-44228, CVSS 10.0, actively exploited in the wild).
- P0 — IMMEDIATE:** Upgrade `jackson-databind` 2.9.8 → 2.13.4.2 (55 CVEs, CVSS 9.8 deserialization RCE chains).
- P1:** Upgrade `mysql-connector-java` 8.0.30 → 8.0.33 and resolve GPL-2.0 license violation.
- P1:** Remove untrusted HTTP repository `http://insecure-mirror.example.net/maven2` from `pom.xml`.
- P2:** Upgrade `commons-io` 2.4 → 2.15.1 (CVE-2024-47554 path traversal, CVSS 7.5).
- P2:** Upgrade `guava` 24.1.1-jre → 32.0.0-jre (CVE-2023-2976, insecure temp dir creation).

8. **P3**: Upgrade `commons-lang3` 3.4 → 3.14.0 (CVE-2025-48924 ReDoS).

Machine-readable sources: `depscan-report.json` , `depscan-risk-report.json` . Ready for Auto-Remediation Skill (Stage 3) and PR Validation Agent (Stage 4).